

RESOLUTION OF FILE OF ACTIONS

From the actions carried out by the Spanish Agency for Data Protection and based on the following:

FACTS

FIRST: Mr. A.A.A. (hereinafter, the complainant) filed a complaint with the Spanish Agency for Data Protection on January 19, 2024. The complaint is directed against XFERA MÓVILES, S.A.U. with NIF A82528548 (hereinafter, the complained party or Xfera). The reasons for the complaint are as follows: The complainant states that on June 27, 2021, his ID card was stolen from his vehicle, and he filed a police report. He indicates that the person who committed the theft went to an establishment of the complained party, requesting a SIM card for his phone. He notes that they provided a copy of the SIM card, resulting in a theft of XXX euros from his bank account.

Along with his complaint, he submits:

- Police report to the Civil Guard, dated June 28, 2021. - Utebo Post - Report No. ***REPORT.1, through which the complainant states the theft of a mobile phone, which had a SIM card with number ***PHONE.1, a metal cardholder containing the ID card in his name and credit cards.
- Extension of the report, dated July 8, 2021, to the Civil Guard - Utebo Post, correcting the error of the mobile number, which is ***PHONE.2, stating that they accessed his main mobile phone at ***PHONE.3, that they cloned the SIM of ***PHONE.3 and carried out a theft of XXX euros through the BIZUM application.
- Attached are the documents detailing the BIZUM transactions, showing the beneficiary's details and the times at which these transactions were made.

SECOND: In accordance with Article 65.4 of Organic Law 3/2018, of December 5, on the Protection of Personal Data and Guarantee of Digital Rights (hereinafter LOPDGDD), the complaint was forwarded to the complained party for analysis and to inform this Agency within one month of the actions taken to comply with the requirements set forth in data protection regulations.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

The forwarding, which was carried out in accordance with the provisions of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP), was acknowledged on March 11, 2024, as evidenced by the acknowledgment of receipt in the file.

On April 14, 2024, a response was received by this Agency indicating:

“As this Agency is aware, to obtain a duplicate SIM card, it is necessary to provide the original identity document, which, in the case of the interested party, is explained by the unfortunate theft of his national identity document a few days before the reported events. In this regard, Royal Decree 1553/2005, of December 23, which regulates the issuance of the national identity document and its electronic signature certificates, establishes in its Article 1.1 that ‘The holder shall be obliged to safeguard and preserve it.’ In this sense, my client had no way of knowing that the interested party's ID had been stolen, so the first layer of security in issuing duplicate SIM cards was breached for this reason. Continuing with the case at hand, the interested party provides information about the transactions made through Bizum, with activity in his account from 20:17:32 on July 7, 2021.

At 20:22:20, an alarm was triggered in my client's fraud detection system. (...) We provide below the details of the alarm. At 20:25:25, three minutes after detection, SMS reception was blocked on the interested party's line by one of the service control agents, preventing SMS reception on the affected line from that moment. The block was lifted on July 8, 2021, once the line was recovered by the interested party and the appropriate checks were carried out by the service control personnel with the interested party.

Regarding the theft of money through BIZUM, there are elements that we do not know and that we

consider relevant to understand what actually happened in this case, particularly concerning the detection times of the fraudulent duplicate by the fraud systems. These issues would be necessary to determine whether the security measures implemented by my client functioned correctly in preventing and detecting the issuance of the duplicate SIM card in this case, since, as this Agency knows, my client has a layered security system in which the request for the ID, which in a case like this, where the ID has been stolen, is an additional measure.

For example, as BIZUM informs on its website regarding its operation, it indicates that the transfer is made directly by the bank, which is delegated the function of authenticating the customer. In this regard, they indicate that they must authenticate the purchase from the banking application.

In the case at hand, no information is provided about the banking application that was affected. If, as BIZUM indicates, it is necessary to complete the operation in the banking application to confirm the transactions, this implies that the...

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

3/7

Cybercriminals had access to the interested party's banking application, which should have had a two-factor authentication: user and password and a second unknown factor, which could be an SMS or another method, such as biometrics.

(...).

Unfortunately, due to the time that has passed, we do not have information on the traffic from July 7, 2021, which would have helped clarify, along with the system logs, the events experienced by the interested party and to evaluate the effectiveness of the security measures implemented by my represented party.

Another option could be that the second factor of authentication to access the bank application did not consist of an SMS, which would imply that the cybercriminals at least had knowledge of the interested party's account number and their access credentials to such account, including the two-factor authentication. Another question we raise is if the criminal had access to the banking application, as well as the second factor of authentication (SMS), why did they choose to send money through BIZUM, when this platform has a limit and did not make a bank transfer, which could be explained if the SMS was not the second factor of authentication to access the banking application and, therefore, the cybercriminal had much more information about the interested party and the unknown second factor, completely unrelated to my represented party."

THIRD: On April 17, 2024, in accordance with Article 65 of the LOPDGDD, the complaint filed by the claimant was admitted for processing.

LEGAL GROUNDS

I

Competence

According to the functions conferred on each supervisory authority by Article 57.1 a), f) and h) of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR) and as provided in Articles 47 and 48.1 of Organic Law 3/2018, of December 5, on Personal Data Protection and Guarantee of Digital Rights (hereinafter LOPDGDD), the Director of the Spanish Data Protection Agency is competent to resolve these investigative proceedings.

Furthermore, Article 63.2 of the LOPDGDD states: "The procedures processed by the Spanish Data Protection Agency shall be governed by the provisions of Regulation (EU) 2016/679, this organic law, the regulatory provisions issued for its development and, insofar as they do not contradict them, subsidiarily by the general rules on administrative procedures."

II

Legality of processing

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

4/7

Article 6 of the GDPR details in its paragraph 1 the circumstances under which the processing of third-party data is considered lawful:

“1. Processing shall be lawful only if at least one of the following conditions is met:

- a) the data subject has given consent to the processing of their personal data for one or more specific purposes;
- b) the processing is necessary for the performance of a contract to which the data subject is party or in order to take steps at the request of the data subject prior to entering into a contract;
- c) the processing is necessary for compliance with a legal obligation to which the controller is subject;
- d) the processing is necessary to protect the vital interests of the data subject or of another natural person;
- e) the processing is necessary for the performance of a task carried out in the public interest or in the exercise of official authority vested in the controller;
- f) the processing is necessary for the purposes of the legitimate interests pursued by the controller or by a third party, except where such interests are overridden by the interests or fundamental rights and freedoms of the data subject which require protection of personal data, in particular when the data subject is a child.

The provision in point f) of the first paragraph shall not apply to processing carried out by public authorities in the performance of their tasks.”

III

Prescription

Article 83.5 of the GDPR states the following:

“5. Infringements of the following provisions shall be subject to administrative fines of up to 20,000,000 EUR, or in the case of an undertaking, an amount equivalent to up to 4% of the total annual global turnover of the preceding financial year, whichever is higher:

- a) The basic principles for processing, including the conditions for consent under Articles 5, 6, 7, and 9.”

The LOPDGD, for the purposes of the prescription of the infringement, qualifies in its Article 72.1 of C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

5/7

very serious infringement, in this case, the statute of limitations is three years, “b) The processing of personal data without any of the conditions for lawful processing established in Article 6 of Regulation (EU) 2016/679.”

III

Claim

In this case, the claimant submits a claim against the respondent for an alleged violation of Article 6 of the GDPR regarding the lawfulness of the processing of their personal data because their personal data has been used without their consent to obtain a duplicate of their SIM card after their ID card was stolen.

IV

Conclusion

From the actions taken and the information obtained, the respondent does not infer negligent conduct in the provision of the duplicate SIM card for the claimant's line. The information obtained indicates that the respondent followed the protocol established for identifying the applicant for the SIM card, without prejudice to the possibility that the applicant may have impersonated the claimant due to the theft of their ID card. Considering the above, the respondent acted by implementing appropriate measures, but the outcome was not as expected.

All these actions indicate compliance with reasonable diligence on the part of the respondent, and they

cannot be held responsible for treatments carried out due to identity theft if they followed the established security protocols.

Therefore, the processing carried out by the respondent complies with the provisions of Article 6 of the GDPR and, without prejudice to the possibility that this relationship may be questioned before the corresponding judicial authority given that the claimant states and reported to the Police that someone impersonated their identity using their personal data to contract with the aforementioned telecommunications operator using copies of identifying documents such as their ID card.

The documentation in the file indicates the absence of the subjective element of culpability necessary in the actions of the respondent to exercise the sanctioning power.

In this regard, the Judgment of the National Court of March 22, 2012 SAN 1465/2023 addresses a similar case in the following terms "(...) that is to say, according to what was agreed, the establishment required the corresponding documentation to verify whether the holder of the card matched the one appearing on the ID card and with the photograph contained in the identity document, noting in the aforementioned sales document the ID number displayed by the customer, which matched with...

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

6/7

the number of the complainant, so the identity of the buyer was verified. (...)

For all of which, and in view of the special circumstances present in the case at hand, it is not possible to appreciate any culpability (not even in terms of negligence or lack of diligence) in the actions of the appealing entity, which acted under the belief that the person with whom it was contracting was who they claimed to be and identified themselves as such with documentation that appeared authentic and corresponding to them, thus being legitimized for the processing of their personal data. Consequently, since one of the requirements necessary for the imposition of a sanction for violation of the principle of consent enshrined in Article 6.1 of the LOPD is lacking, it is appropriate to annul the sanction imposed for the commission of said infringement."

(...)

"For all of which, in accordance with the arguments regarding the infringement of the violation of the principle of consent, it is also not possible to appreciate culpability in the actions of the appealing entity, which acted under the erroneous belief that the debt it processed in its files and communicated to the solvency and credit files was attributable to the person who made the purchase and was obligated to the deferred payment, who identified themselves with the name, surname, and ID number of the complainant, whose identity they impersonated."

Therefore, based on the indications in the previous paragraphs, no evidence has been found to substantiate the existence of an infringement within the jurisdiction of the Spanish Agency for Data Protection.

On the other hand, the possible infringing action of the respondent would be time-barred due to the passage of three years for very serious infringements, as stated in Article 72.1 of the LOPDGDD, starting from the moment of processing by the respondent.

Thus, as it has not been possible to attribute responsibility for the processing and also as the possible infringement is time-barred according to the aforementioned, the Director of the Spanish Agency for Data Protection RESOLVES:

FIRST: TO ARCHIVE the present proceedings.

SECOND: TO NOTIFY this resolution to XFERA MÓVILES, S.A.U. with NIF A82528548 and to the complaining party.

In accordance with the provisions of Article 50 of the LOPDGDD, this Resolution will be made public once it has been notified to the interested parties.

Against this resolution, which concludes the administrative procedure as provided by Article 114.1.c) of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations, and in accordance with the provisions of Articles 112 and 123 of the aforementioned Law 39/2015, of October 1, the interested parties may optionally file a motion for reconsideration before the Director of the

Spanish Agency for Data Protection within one month from the day following the notification of this resolution or directly file a contentious-administrative appeal before the Contentious-Administrative Chamber of the National Court, C/ Jorge Juan, 6, www.aepd.es, 28001 – Madrid, sedeagpd.gob.es 7/7

in accordance with the provisions of Article 25 and in paragraph 5 of the fourth additional provision of Law 29/1998, of July 13, regulating Contentious-Administrative Jurisdiction, within two months from the day following the notification of this act, as provided in Article 46.1 of the aforementioned Law.

Mar España Martí

Director of the Spanish Agency for Data Protection

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es